615 Final Project
Security Plan for Van615 Hotel

PROFESSOR NAME: [redacted]

Group Polar
[redacted] **| Student Number:** [redacted]
[redacted] **| Student Number:** [redacted]
Yanqing Li | Student Number: [redacted]

INCS-615: Advanced Network and Internet Security

April 22, 2022

Abstract:

Van615 Hotel, a medium-sized hotel, has had several incidents since 2021, which resulted in data breaching, data loss, blackmail, operation breakdown, etc., This paper identifies potential causes of the issues. A security plan is proposed to mediate the effects of existing issues and to prevent similar problems from happening in the future. This paper goes through the current company architecture to identify other possible vulnerabilities and threats and provides suggestions.

The main challenge here is that policy and staff training, as well as other techniques addressed in the mythology part is limited to an idealistic situation, which is simply tested in programs based on the theorem. All security plans in reality are based on the budget and the tradeoff between convenience and security level. This security plan covers access control, authentication message, data storage, communication, and connection security, device security, employee training, and backup & hazard plan. The design and techniques used are listed in detail in the Problem Analysis and Circumstance Setup section. It is specifically targeted at the current scene. Final recommendations and remarks are provided in the Conclusion section of this paper.

I. Introduction:

The Van615 Hotel has had several incidents in 2021 including data breaching, data loss, and operation breakdown. The hotel's manager decided to use our security team to assess their security and prepare a new security platform for asset protection. Our team is tasked to provide a security plan and configuration based on the priorities and policies of the hotel. Based on the CIA Triad, which contains Authentication, Authorization, Accountability, Confidentiality, Integrity and Availability, our team analyzes the current network structure and the sample problems and proposes solutions and suggestions for Van615 Hotel.

II. Background:

Because Van615 Hotel is a medium-size hotel, we are to assume that their resources and budget are limited. The main function of the Internet is to have an online reservation system and provide high-speed internet access (HSIA) services for guests in public areas and guest rooms.

The network structure of Van615 Hotel is a three-tier architecture, containing the web tier, the business tier, and the data tier. The web tire is for online reservation services with communication is based on the HTTP protocol. It may contain sensitive information considering it is a remote service. We are to ensure the CIA triads are performed, which requires extra security to ensure authenticity and confidentiality. As it is directed toward the guests, we identify security and availability are our priorities. The Business tier handles all the information and performs the main business function in this hotel. Because the remote reservation center is located in multiple areas, and the hotel reservation goes through from web tier to business, we ensure availability first, then integrity and confidentiality. Lastly, the data tier, which stores all this information, and all information are saved in a cluster of database servers.

The internal network is also instrumental as it connects all departments. The hotel has an HSIA network for internet service for guests, which separates the internal user and external users. Since the current internal connections are flat, we need to separate them for different departments and give them different levels of security, to make sure there is no read-up and no write-down to leak any information. It is confirmed that there is no active directory deployed in the internal network and in workgroup mode. Given the consideration of some of the data ports for internal networks are located in the public area such as outlets and lobbies, adjustments are to be made to their locations and ensure these ports are protected.

The last one is staff training since the Hotel permits the use of personal phones for work and their local connections to the Internet. As it allows working remotely for the employees, it is possible to contain security level problems. However, with correct permissions and training, this issue can be easily ameliorated. If the Hotel bans the use of personal devices, it will take a toll on the performance of the employees. Since Van615 is a medium-size company, the tradeoff should be convenience and cost-orientated first.

III. Problem analysis and circumstance setup:

Based on the available background information, the company's incidents in 2021 resulted in data breaching, data loss, and operation breakdown. Our group has analyzed 5 sample problems and provided solutions. We then drew hypotheses for threats and vulnerabilities based on the current architecture. We listed our security plan and structure in detail in the next section. We also provided suggestions for the future of the business in the conclusion. Also, we may talk a little about the unsolved problems as well. Our main architecture aims to provide the leading security services based on Authentication, Authorization, Accountability, Confidentiality, Integrity, and Availability. First, we start with the internal network problems started in the lobby. Guests could have access to the hotel's internal network by plugging in their cable to the ports located in the lobby. We chose to opt for the 802.1x protocol for setting a self-built network topology to make sure the internal network is only available for the employee under permissions. We have made a simple flow chart about how to set up the 802.1x.

Since the hotel received several complaints about interrupted communications. The Man-in-the-middle attack is responsible for what happened in the public and guest rooms' high-speed internet access (HSIA) network. The Hotel needs to remind the guests from phishing and the hotel needs to provide verification and protection from encryption. This issue needs to have operations on both sides to avoid it, the hotel and client need to work together. Hotels need to remind the guests to use VPN for any sensitive information and keep an eye on the public hotspot or fake Wi-Fi. The hotel will provide the key card for the room, and usually, there will be a Wi-Fi username and password beside the keycard. It is not uncommon for guests to make mistakes while entering the network information, which is why we could have loaded the information into the keycard by using NFC technology. By simply using their smartphone, it can direct the guest to the right page to set up the connection. Then, for the hotel, we could add more security mechanisms to the router, such as setting up the WPA3 on the router for encryption and the hotel can set up the firewall for the network monitor and filter, which can help our clients away from the non-secure link and other sniffing for the connection in the hotel. It can help the hotel can avoid taking the liability for the primary fault party if there is a major problem happens.

We had also witnessed that in our internal network, several critical systems in each department were out of access as they were encrypted by the ransomware attacks, and ransom was demanded by the attacker for the return of information. Ransomware software allows the attacker to restrict access to systems by encrypting/capturing system files, data, or resources and demands financial payment [redacted] et al., 2021). There are some ways we can use to mitigate, detect, predict, and prevent and then fulfill the confidentiality, integrity, and availability (CIA). To achieve this goal, we could take into consideration these procedures: preparation, detection, containment, eradication, and recovery [redacted] 2016). For preparation and recovery, the hotel could update/patch their systems and create and protect back-ups in separate disks, [redacted] et al., 2019). For detection, containment, and eradication, we may use specific methods to solve these problems as below [redacted] et al., 2019).

After implementing the above procedures, it can analyze, detect, prevent ransomware, and mitigate losses for the hotel. Preparation, detection, containment, eradication, and recovery [redacted] 2016) preparations and implementation, these methods can efficiently delimit the damage. The details are listed details in the following table 1.

Method	Technique	Problem addressed
JentFOS [redacted] 2016)	Bayesian Network-based Analysis	Detection of highly survivable ransomware and prevention of backup intrusions or access
SdOsand [redacted]	Stack Activity Analyzer, I/O log Analyzer	Regulate access rules and avoid ransomware attacks on external devices
Honeypot [redacted]	Honeypots and IDS to screen network logs	Automated tool to detect both active and passive malware in android environment
PRF [redacted]	Process monitoring, Backup and recovery layers	Multi-layered approach to backup and recovery attacks

Table.1 Ransomware software related Method and Technique

The last part of the internal problems is the data breaching of reservation information, which contains sensitive information such as guests' credit card information. There are two ways to help reduce the possibility of happening. The first is deploying an audit system to the database. Hotels are required to create detailed log records to facilitate retrospective investigation of specific events after the fact. This issue includes logs of mobile storage device usage, operation of terminals such as printers, logs of hotel system servers, logs related to permission adjustments, etc. The second way is to implement a database firewall system to stop SQL injection attacks and override operations. There are systems that are more important and vulnerable to hacker attacks, such as databases that provide scheduled services to the outside world, where we need to add a firewall outside the database.

In order to prevent staff from unintentionally causing damage to the databases due to operational errors, the hotel needs to limit the impact behaviors such as updates and deletions. Administrators receive alerts when anomalies are monitored to occur. A protection system is also needed to shut down anomalous behavior or connections in time to ensure that the service is always available. More extensive staff training is required to work on the database for security reasons because they can easily reach the data from the inside system, which means that the hotel needs to provide one-way hashing for clients' info. Providing different privilege control for different user groups is also necessary. Each employee has different permissions to operate on the data. We divide them into different user groups according to their roles. To secure the database, detailed rights control is provided for employee security levels.

After the internal network issues, the external network is also facing a lot of challenges. The hotel's reservation is down due to the DDOS, and DDoS stands for Distributed Denial of Service, which is causing the availability problem, and clients will not be able to use the services. The firewall will be able to help the hotel prevent a part of DDOS because we can set rules to deny certain requests. We can use the firewall to filter the malicious address and deny their service. Since most of the remote reservation can be done using the hotel's web-based application, and there is no direct connectivity to the headquarter, communicating over the Internet is current, so, the hotel can also remain a pool for availability to make sure the service is on but slow. In the meantime, it can go over the request pool to shut down the service for those who only request but do not respond. The remote reservation centers are in several cities and airports, so we can set some exchangers in these locations to help the host server to identify the fake address and filter the clients, and make sure the connections work for the client. If the hotel opts to invest more in preventing the DDOS attack, it can be done through the Anti-DDOS attack program or service or some other human-checking program to help prevent DDOS attacks.

After solving these identical problems, our group has made some assumptions about the vulnerabilities based on these problems, and the hotel's network architecture. Then, we list the detailed security plan to avoid more incidents happening in the future.

IV. Security plan:

In the hotel's current high-speed Internet access infrastructure, there are not any external and/or internal firewalls, which implies that any PC or mobile devices could access the HSIA infrastructure. This issue could potentially pose threats where attackers can breach this infrastructure and result in losses. Furthermore, the open access to the HSIA Internet and the network, as well as the limited bandwidth of the Internet has proven to be a significant burden that would result in a worsening reception for the guests. The details are listed in the following Fig. 1

To secure the current HSIA, enhancing the infrastructure using firewalls with IPsec can protect the hotel's network and improve the experience for guests. The improvement of current HSIA is as follows:

1) Separating the public area and guest rooms into two different routers, reduces the threats from the public area with open access to the network.

2) Using firewalls with IPsec to enhance the HSIA network where firewalls can filter all packets and discard any if needed.

3) Setting firewalls with IPsec to prevent any threats from the external sources using the IPsec. If an unauthorized user wishes to access the hotel's network, the firewall will reject this request and protect the network.

4) In each LAN switch, a firewall is set with IPsec into the local network (guest rooms). Even if there exist threats from a

particular guest room, effects will be limited to the current network of the guest room without compromising others.

Considering budgetary limitations, heavy investments in current infrastructure will not be ideal. Privileges and recommendations are listed as follows:

1) We strongly suggest separating the public area and guest rooms into two different routers using firewalls to decrease threats from public users.

2) We highly recommend that the hotel uses firewalls from the Internet to protect confidentiality and integrity.

3) We suggest attaching IPsec with each firewall due to budgetary limitations.

4) We suggest using the firewalls to filter the packets from the boundary router to the LAN switch as an alternative.

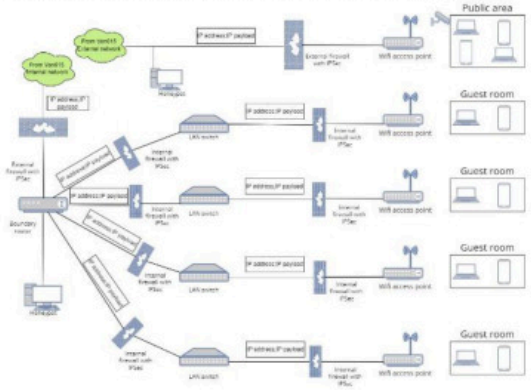


Fig.1 New High-Speed Internet Access Infrastructure of Hotel

V. Explanation of topology and structure

For the hotel's remote office areas, including airport counters, remote booking centers, etc., we have added security measures such as firewalls and honey pots to them. The details are listed in Fig.2

When the guests booked hotel services using the remote booking system before, the hotel provided web services based on HTTP protocol and it was not secure. After the structural change, the web booking service uses HTTPS.

After the change of the hotel network structure, for remote home offices, airport receptions, and remote booking centers, employees need to access the hotel network via VPN.

The hotel network is divided into two parts: the office extranet and the business intranet. With the development of businesses such as remote booking services, the need for data interaction between the two parts also arises, so the design deploys a safety isolation gate system between the two parts for network isolation, and the data from the extranet area that needs to access the business intranet is swung through the net gate.

The different parts are listed in detail below.

(1) Office, extranet area

- The external network mainly carries office systems, operation management systems, etc.
- Internet access area: a series of security measures including firewall and intrusion prevention systems are deployed after the external network.
- External service area: system servers such as a remote booking service.
- External security zone: network audit, operation, and maintenance management servers, etc.
- External office area: this part of the area is located in the hotel lobby and is mainly concerned with office terminal access.

(2) Business intranet

- External network security area: log auditing, operation, maintenance management servers, etc.
- Internal service area: the hotel's main business file server and database.
- Internal office area: intranet office terminal equipment.

A detailed description of the structure is listed below,

1) By deploying a switch that supports 802.1X protocol, the client makes an authentication request at the switch and the AAA authentication system of RADIUS decides whether to open the switch port and grant the client access to the hotel network based on the information submitted by the user. By analyzing the traffic logs of the switch, the source IP address of the network security event is determined, enabling monitoring of the network operation.

2) VLAN division of the hotel's guests and different departments, each VLAN cannot directly access each other, to achieve a clear network structure and inter-access control between departments, so that there will be no attacks and virus transmission between the VLANs.

3) Deploy a firewall supporting VPN technology between the internal and external networks to achieve internal and external network isolation and access control while allowing users to use VPN technology to transmit data

4) Deploy an intrusion detection system and a network anti-virus gateway. The intrusion detection system detects, and analyses abnormal network behavior and site content posted on the hotel website and determines the source IP address of network security events. The anti-virus gateway can effectively prevent the spread of viruses over a large area.

5) The information of users is collected through RADIUS proxy to achieve the correlation information of user accounts, IP addresses, switch numbers, and port numbers, which is provided for network security event tracing.

6) Network security policy can be issued through RADIUS agent in a timely manner

7) Data encryption authentication technology: Data encryption technology can protect the integrity and confidentiality of data

by encrypting the data. Wireless users can use VPN or SSL VPN technology to achieve encrypted data transmission.
Previous guests could access the hotel's intranet from the hotel lobby, but now there is a segregation of the hotel's intranet data through a network gate.

Because of previous data breaches at the hotel, an audit system and intrusion prevention system were added before the database and servers.

In the old structure of the hotel network, all servers were placed together. But the server responsible for remote bookings was to provide a service to the outside, which had to be accessible to the outside, while the server storing the data needed to be well protected. The new topology solves this problem very well.

If the hotel has the budget, a firewall can be added in front of each host and server. This allows a distributed firewall configuration to be used to protect the hotel's secure network.

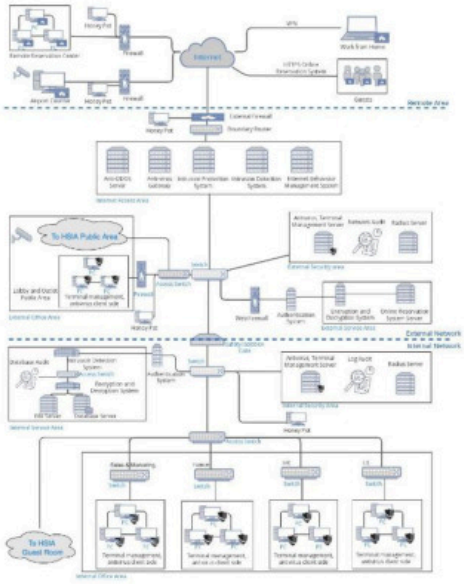


Fig.2 Van615 Hotel Network Infrastructure

After our team designed the security plan, we list some advice based on the urgent level for setting up the security plan.

1) We strongly recommend the use of Firewalls to reduce threats from the public, which protects the confidentiality and integrity of the hotel.

2) We strongly recommend the use of Radius for user authentication; only authenticated users are allowed to log into the hotel network.

3) We strongly recommend the use of anti-virus software on the office hosts; this will ensure that the wide spread of viruses from the hotel is prevented.

4) We also recommend deploying honeypots next to some important parts, which is an option if the budget is limited (optional).

5) We also recommend that IDS and IPS are deployed to detect and analyze unusual network behavior and content, which is an option for hotels (optional).

6) We may recommend that an auditing system is deployed in the switch bypass to audit and monitor network behavior (optional).

VI. Conclusion:

In this article, our team has analyzed the current problem happening in the Van615 Hotel, such as data breaching, data loss, and operation breakdown. These problems are heavily influencing the CIAAA rules for hotel security.

Given the consideration of the Van615 Hotel is a medium-size company, when our team does the analysis, the budget and resources are being considered limited. So, our team is giving a list of changes based on its priority of it.

In the process of analysis, due to the lack of specific information or details. Our group has to make their own assumption based on the current situation and formulate a general plan for preventing the current events.

The structure of this security plan refers to many fields of the hotel, such as the internal network and external network for different departments, and our team has provided an access matrix in the appendix for employees of different departments and the tires of the hotel, and all the suggestion listed in the article is in an ideal situation and based on the priority. The table.2 has shown the detailed access matrix for the hotel's different department has access to what data.

Data Kind	Storage Location and Execution Location	Sales and Marketing	Finance	Human Resource	Information and Technology
Customer's Info	Data Tier	read & write	read & write	n/a	read
Employee's Info	Data Tier	n/a	read & write	read	read
Payment Info (History payment record)	Data Tier & Business Tier	read	readd& write	n/a	read
Reservation Info and Hotel room availability Record	Data Tier & Web Tier	read & write	n/a	n/a	read & write

Table.2 Access Matrix

The new security plan is formulated for Van615 Hotel's after the process of analysis. The new security plan contains basically 3 parts, the first one is the High-Speed Internet Access Infrastructure of the Hotel, which mainly serve the clients' need in the public lobby and their private room. The second is the Internet Structure for the internal users and different departments. It shows how the internal structure works. The third one is the Hotel Network Infrastructure; it shows the entire online system and how it works. These formats the security topology of the structure.

Fully implementing this security plan also need well-trained employees. Since the hotel is monitored and executed its function by people, if the employee is not well-trained, then their behavior is hard to predict what kind of accidents would executors in the system.

With the development of technology, the cyber-attack and the defense will be more intense in the future. And nothing is secure forever. The arise of the potential security will threat the protection level of security plan. Therefore, the security measures need constant updates according to the development of technology to ensure security is also up to date.

Reference:

[redacted] M. M., & [redacted] H. R. (2016, September). 2entFOX: A framework for high survivable ransomwares detection. In 2016 13th international iranian society of cryptology conference on information security and cryptology (ISCISC) (pp. 79-84). IEEE.

[redacted] R. (2016). Ransomware attacks: detection, prevention and cure. Network Security, 2016(9), 5-9.

Cvent.com. 2022. *Hotel Cybersecurity: A Guide to Avoiding Threats | Cvent Blog*. [online] Available at: <https://www.cvent.com/uk/blog/hospitality/hotel-cybersecurity> [Accessed 21 April 2022].

Federal Communications Commission, "Cybersecurity for Small Business", fcc.gov, 2021. [Online]. Available: https://www.fcc.gov/general/cybersecurity-smallbusiness. [Accessed 21 April 2022].

[redacted] S., [redacted] C., [redacted] B., & [redacted] J. (2017). Sdguard: An android application implementing privacy protection and ransomware detection. In Proceedings of the International Conference on Mobile Systems, Applications, and Services, ser. MobiSys (Vol. 17, pp. 149-149).

[redacted] C. (2016). Detecting ransomware with honeypot techniques.

[redacted] J., 2022. *Hotel Safety and Security Checklist [12 Vital Protections]*. [online] Realtimenetworks.com. Available at: <https://www.realtimenetworks.com/blog/hotel-safety-and-security-checklist> [Accessed 21 April 2022].

[redacted] M., [redacted] S., [redacted] Q., & [redacted] M. (2017). Multi-layered defense architecture against ransomware. International Journal of Business and Cyber Security, 1(2).

Protection, S. and System, E., 2022. *Securing the Hotel Industry from Cyber Threats: Pandemic Lessons and 8 Best Practices to Improve Data Protection*. [online] Ekransystem.com. Available at: <https://www.ekransystem.com/en/blog/cyber-security-in-hotels> [Accessed 21 April 2022].

[redacted] T. R. (2021). Information security breaches due to ransomware attacks-a systematic literature review. International Journal of Information Management Data Insights, 1(2), 100013.

[redacted] J. A. H., [redacted] L. I. B., [redacted] Á. L. V., & [redacted] M. (2019). A survey on situational awareness of ransomware attacks—detection and prevention parameters. Remote Sensing, 11(10).

Zeguro, "101 Cybersecurity Tips for Small to Midsized Businesses (SMBs) | Zeguro Blog", Zeguro.com, 2021. [Online]. Available: https://zeguro.com/blog/101-cybersecurity-tips-forsmall-to-midsized-businesses-smbs. [Accessed 21 April 2022].

Appendix:

Method	Technique	Problem addressed
2entFOX [redacted] & [redacted] 2016)	Bayesian Network-based Analysis	Detection of highly survivable ransomware and prevention of backup intrusions or access.
SdGuard [redacted] et al., 2017)	Stack Activity Analyzer, I/O log Analyzer	Regulate access rules and avoid ransomware attacks on external devices
Honeypot [redacted] 2016)	Honeypots and IDS to screen network logs	Automated tool to detect both active and passive malware in android environment
PRPB [redacted] et al., 2017)	Process monitoring, Backup and recovery layers	Multi-layered approach to backup and recovery attacks

Table.1 Ransomware software related Method and Technique

Data Kind	Storage Location and Execution Location	Sales and Marketing	Finance	Human Resource	Information and Technology
Customer's Info	Data Tier	read & write	read & write	n/a	read
Employee's Info	Data Tier	n/a	read & write	read	read
Payment Info (History payment record)	Data Tier & Business Tier	read	read& write	n/a	read
Reservation Info and Hotel room availability Record	Data Tier & Web Tier	read & write	n/a	n/a	read & write

Table.2 Access Matrix

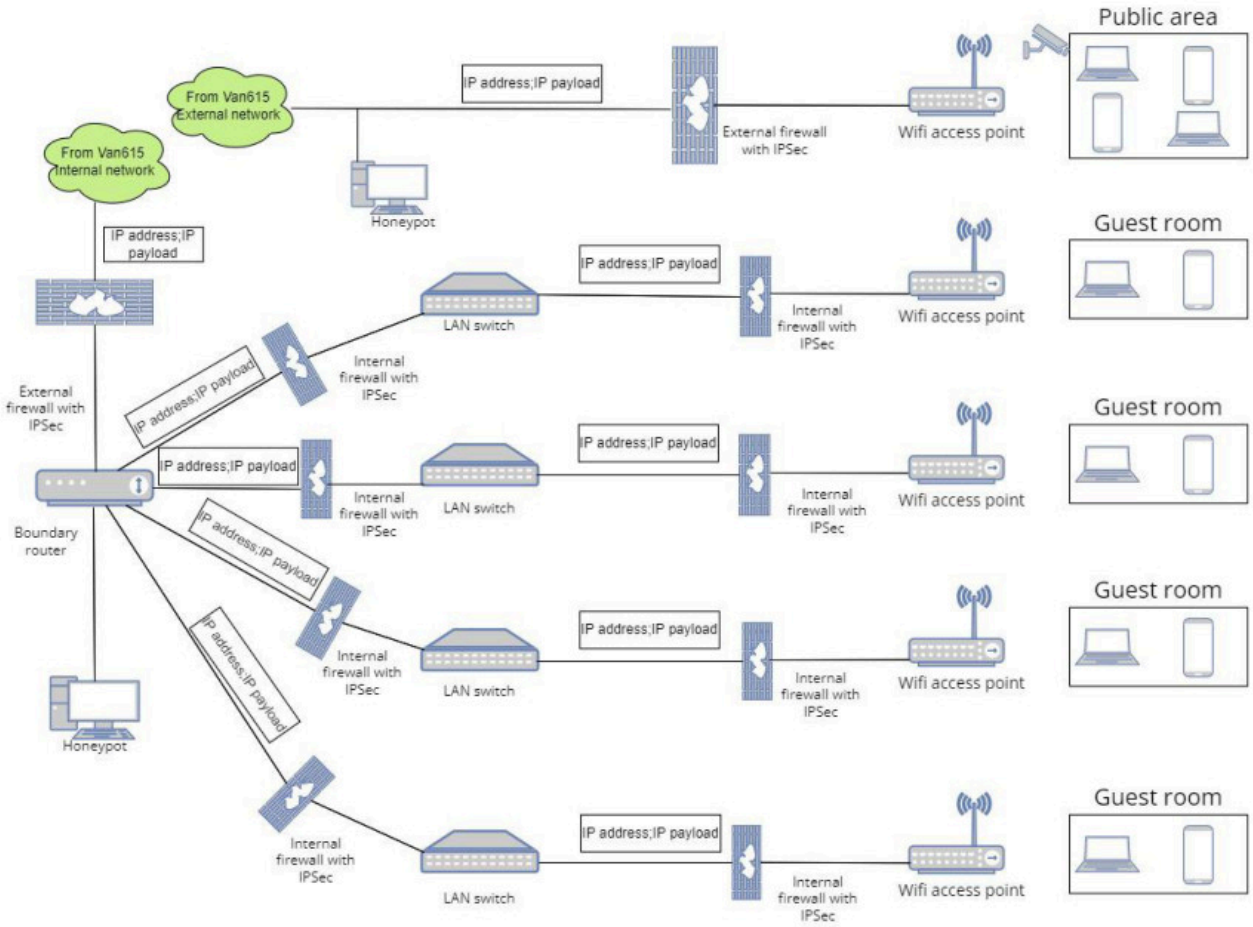


Fig.1 New High-Speed Internet Access Infrastructure of Hotel

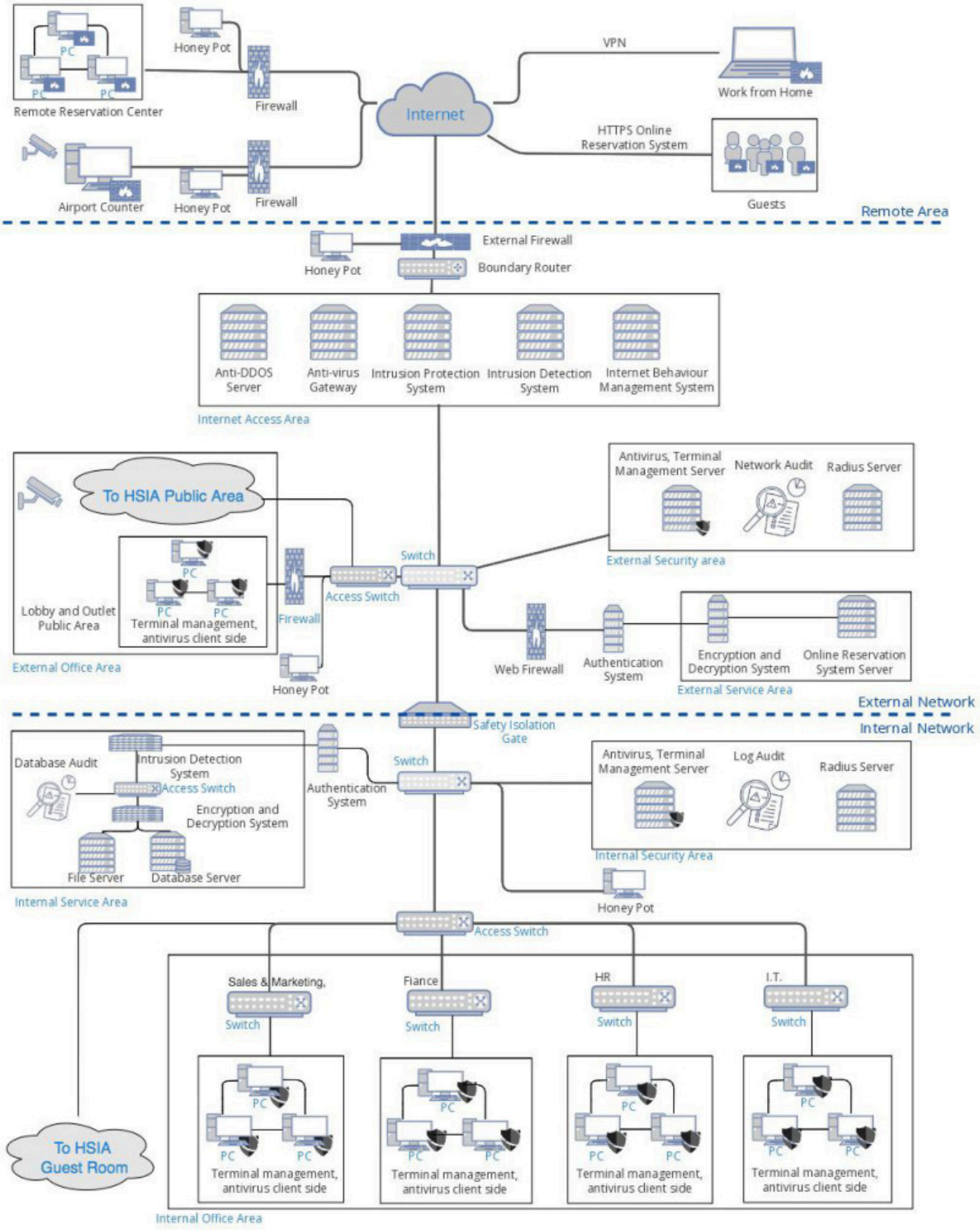


Fig.2 Van615 Hotel Network Infrastructure

APPENDICE

10 Minutes of Meeting 1

Date of Meeting	2022/02/23
Time of Meeting	6:00pm
Team Members	Yanqing Li, [redacted]
Meeting Location	In-Person
Meeting Title	Team Project – Secure Network Architecture
Meeting organizer	Yanqing Li

Agenda details:

Assign Reading and go over the entire project.

Clarify and assign the task.

Meeting notes:

Y: Make the structure of this article and assign workload.

[redacted] Read Material and pick the task.

[redacted] Read Material and pick the task.

30 Minutes of Meeting 2

Date of Meeting	2022/03/09
Time of Meeting	6:00 pm
Team Members	Yanqing Li, [redacted]
Meeting Location	In-Person
Meeting Title	Team Project – Secure Network Architecture
Meeting organizer	Yanqing Li

Agenda details:

Share the background analysis and start working on the specific case.

Meeting notes:

Y: Share the Background and the introduction. Start assign work for the Problem analysis and circumstance setup. DDOS.

[redacted] Credit card info leak, Ransomware.

[redacted] Man in middle attack, Guest login in lobby.

30 Minutes of Meeting 3

Date of Meeting	2022/03/24
Time of Meeting	7:00 pm
Team Members	Yanqing Li, [redacted]
Meeting Location	Online
Meeting Title	Team Project – Secure Network Architecture
Meeting organizer	Yanqing Li

Agenda details:

Go over the security plan.

Meeting notes:

Y: Compile the Problem analysis and circumstance. Connection and adjust format for the security plan.

[redacted] Network (Graph improvement)

[redacted] HSIA (Graph improvement)

30 Minutes of Meeting 4

Date of Meeting	2022/04/12
Time of Meeting	8:00 pm
Team Members	Yanqing Li, [redacted]
Meeting Location	Online
Meeting Title	Team Project – Secure Network Architecture
Meeting organizer	Yanqing Li

Agenda details:

Go over the security plan and finish the project prototype.

Meeting notes:

Y: Compile the security plan. Start assign work for the security plan. Connection and adjust format. Finish the conclusion and make the prototype.

[redacted] Network (Explanations and topology work)

[redacted] HSIA (Explanations and topology work)

10 Minutes of Meeting 5

Date of Meeting	2022/04/20
Time of Meeting	8:00 pm
Team Members	Yanqing Li, [redacted]
Meeting Location	Online
Meeting Title	Team Project – Secure Network Architecture
Meeting organizer	Yanqing Li

Agenda details:

Go over the details and finish the project.

Meeting notes:

None. Final check.